TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

CISA, FBI and partners warn of attacks on industrial refrigeration and cold-chain controllers

From **Cybersecurity Briefing** · 2026-11-05 to 2026-11-06 (US, Global, Industry); 2026-11-01 to 2026-11-06 (Indianapolis and Indiana) · Briefing generated 2026-11-06

REPORT ID	VERSION	HANDLING	BRIEFING SECTION
CTI-20261106-03	1.0 · 2026-11-06 08:05 EST	TLP:CLEAR	Other / OT
ORIGINAL PUBLISHED	**LAST UPDATE**	**CVES**	**ANALYST**
2026-11-05	No update	None	Nick Sturgeon

OT / ICS THREAT ADVISORY | HIGH | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 5 November 2026, CISA, the FBI, HHS, USDA and the Department of Transportation released a joint TLP:CLEAR fact sheet. It warns that malicious cyber actors around the world are targeting electronic temperature controllers and commercial refrigeration controllers in retail grocery, cold storage and refrigerated transport [S3] [S4]. The agencies say the actors may use authentication bypass, arbitrary code injection or weak configurations on unpatched or internet-exposed controllers. With that access they can change setpoints, force units into continuous heating or defrost cycles, and cause a denial-of-view condition in which operators cannot see real temperatures [S3]. The fact sheet names no vendors, products, CVEs, actors or indicators of compromise [S3]. Its mitigations focus on removing internet exposure, isolating OT networks, changing default passwords, patching or replacing end-of-life devices, allowlisting, logging, and enforcing hard setpoint limits with alerting [S3] [S4].

The advisory follows a series of real-world incidents. On the night of 11 October 2026, attackers forced defrost and heating cycles on refrigeration at hundreds of French supermarkets. Estimates range from roughly 250 to 350 stores up to about 700 by French government counts, and the losses include discarded stock and some equipment fires [S1] [S6] [S9] [S11]. CERT-FR alert CERTFR-2026-ALE-012 names the

controllers involved: Danfoss AK-SM and AK-SC series, plus Copeland xweb and Dixell xweb [S5]. Danfoss said most affected units were end-of-life models: the AK-SM 800 (EOL since May 2021) and the AK-SC 355 (phased out in 2016). Some current AK-SM 800A units running outdated firmware were also hit [S6]. A second wave on the night of 1 to 2 November hit more than 115 stores in Belgium, the Netherlands, Sweden, Luxembourg, Ireland and Estonia, with further incidents in Italy and Portugal. In some stores, controllers were set to +50 C and locked [S7] [S9]. On 2 November, three French Blood Establishment (EFS) sites had their cold-storage settings raised through a refrigeration supplier's remote-monitoring software. Alarms caught the change and no blood products were lost [S8]. In the US, freezers at several military commissaries went into defrost in late August, and the Pentagon is investigating these as a suspected hack. No US equipment vendor has been named [S2] [S9] [S11].

How the attackers got in has not been publicly established, and no group has claimed responsibility. Officials in France and Belgium say they do not know who is behind the attacks [S6] [S9]. One press report says US officials suspect Iran-linked hackers for the commissary events, while other reporting points to hybrid-threat concerns involving Russia. Neither view is confirmed [S2] [S9]. Known Danfoss AK-SM 8xxA flaws exist (CVE-2025-41450 authentication bypass; CVE-2025-41451 command injection; CVE-2025-41452). They match the weakness classes the advisory lists, but no authority has tied them to these attacks, and CISA reported no known exploitation when it published ICSA-25-140-03 [S6] [S8] [S10]. The most likely route is internet-exposed web management interfaces, often with default credentials or on unpatchable legacy firmware. Researchers have counted thousands of these interfaces online [S6] [S9].

Food retailers, grocery chains, hospitals and blood or pharmacy storage, food processors, cold-storage warehouses and refrigerated-logistics operators should act within the next day. Find every refrigeration controller and supervisor (Danfoss, Copeland, Dixell and others) that can be reached from the internet, including through contractor-managed connections, and take it off the internet. Restore remote access only through a managed VPN, change default passwords, enable the vendor's strict or HTTPS-only security mode, review defrost schedules and setpoints, and set independent high-temperature alarms [S3] [S5]. Plan to replace end-of-life controllers. CERT-FR warns that a factory reset leaves them open to reinfection [S5].

Key judgments

LIKELY · MODERATE CONFIDENCE

Attacks that tamper with setpoints on internet-exposed refrigeration controllers will likely continue over the next 30 days and spread to additional countries or sectors. Opportunistic copycats may also join, because the technique needs little skill against exposed legacy devices and both European waves drew wide media attention. [S3] [S5] [S7] [S9]

LIKELY · MODERATE CONFIDENCE
US organizations that run internet-exposed or default-credential refrigeration supervisors, including grocery, healthcare and cold-storage operators, are likely to see scanning or login attempts against those interfaces in the near term. Decoy sensors already recorded default-credential login attempts against Danfoss AK-SM interfaces in late October. [S3] [S9]

UNLIKELY · MODERATE CONFIDENCE
A public attribution of the European supermarket waves to a named state or criminal actor within the next 30 days is unlikely. Investigators in France and Belgium have said the perpetrator is unknown and may never be identified. [S6] [S9]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
There is a roughly even chance that CISA or a vendor will publish specific CVEs or indicators tied to this campaign within the next 30 days. Investigations are active in several countries and an ANSSI-reported vulnerability has been passed to a vendor, but no official IOCs have been released so far. [S3] [S5] [S6]

INDICATORS OF COMPROMISE

Neither the joint fact sheet nor CERT-FR alert CERTFR-2026-ALE-012 publishes network indicators (IPs, domains, hashes) [S3] [S5], and the press coverage reviewed lists none [S1] [S2] [S7] [S8]. The entries below are behavioral and exposure indicators taken from incident reporting between October and early November 2026. Items marked derived are inferences about which interfaces and behaviors to watch, not observed attacker infrastructure.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Refrigeration controller setpoint changed to +50 C (122 F) and locked against operator change`	Reported effect in the second-wave incidents, for example at an ICA store in Sweden and a Selver freezer in Estonia. Units were set to about +50 C and in some cases could not be changed back locally.	REPORTED	2026-11-02	[S1] [S7] [S9]
other	`Forced or continuous defrost cycle triggered remotely outside the scheduled defrost window`	This was the main technique in the October French wave and the November European wave, and the same symptom appeared at US commissaries in August. Watch for defrost-schedule changes and defrost events outside the normal schedule.	REPORTED	2026-08-26	[S3] [S5] [S6] [S11]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Raised temperature and defrost thresholds on cold-storage chambers via third-party remote monitoring software`	The EFS blood-storage incident: three sites had chamber thresholds raised to extremely high levels through a refrigeration provider's remote-monitoring software, and alarms detected the change.	REPORTED	2026-11-02	[S8]
other	`Login attempts using factory-default credentials against Danfoss AK-SM web interfaces`	A deception vendor's decoy sensors recorded these attempts from 20 to 30 October 2026, peaking on 26 October, as summarized by EDRM. No source IPs were published.	REPORTED	2026-10-20	[S9]
other	`Danfoss AK-SM / AK-SC, Copeland xweb, Dixell xweb management interface reachable from the internet`	CERT-FR names these products as compromised and says internet exposure of their management interfaces is the core risk. An internet-reachable instance is an exposure indicator to fix, not evidence of compromise.	REPORTED	2026-10-12	[S5] [S6]
port	`TCP 80 / TCP 443 (controller embedded web management interface)`	Derived. The affected controllers are managed through an embedded web server, and Danfoss Strict Session Control enforces HTTPS. Inbound HTTP or HTTPS from the internet or from unexpected internal hosts to controller IPs is the access path to monitor. Some deployments may use non-standard ports, so check each site's actual configuration.	DERIVED		[S5] [S6] [S10]
http-request	`Successful web session or configuration write to a refrigeration supervisor from a source IP not on the contractor allowlist`	Derived from the advisory's recommendation to allowlist only devices and IPs authorized to make changes [S3]. Any configuration change from outside that list should be treated as suspicious.	DERIVED		[S3] [S5]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

The actors reach refrigeration supervisors and controllers that are exposed to the internet, often legacy Danfoss AK-SM 800 or AK-SC 355 units with no available patches, or AK-SM 800A, Copeland xweb and Dixell xweb units on outdated firmware. They get in through weak or default credentials, authentication bypass, or code injection in the embedded web management interface [S3] [S5] [S6]. The exact entry vector for each wave has not been published. Once inside, they change control parameters: they raise setpoints (around +50 C in several stores), trigger continuous defrost or heating cycles, change defrost schedules, and in some cases lock settings so operators cannot reverse them or see accurate temperatures. The result is stock spoilage, equipment stress and fire risk [S3] [S7] [S9]. Some activity reached victims through a refrigeration contractor's or supplier's remote-monitoring platform rather than the victim's own network, as in the EFS incident and Leclerc's supplier statement [S6] [S8]. CERT-FR notes that factory resets remove persistence but do not fix the underlying weakness on end-of-life devices, so reinfection is possible [S5].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T0883 Internet Accessible Device	Actors reach refrigeration controller management interfaces that are directly exposed to the internet, and the agencies and CERT-FR name this exposure as the main risk. [S3] [S5] [S6]	Run external attack-surface scans for controller web interfaces, and alert on inbound internet sessions to OT controller IPs at the perimeter firewall.
Lateral Movement	T0812 Default Credentials	Actors try factory-default credentials against Danfoss AK-SM interfaces (observed by decoys from 20 to 30 October), and the advisory lists weak configurations as a vector. [S3] [S9]	Review controller and supervisor authentication logs for logins with default accounts and for repeated failed logins from external sources.
Initial Access	T0866 Exploitation of Remote Services	The fact sheet names authentication bypass and arbitrary code injection in unpatched controllers as vectors. Known AK-SM 8xxA flaws of these types exist, but none has been confirmed as used. [S3] [S10]	Inspect HTTP requests to controller web interfaces for unusual paths or parameters, and flag devices running firmware older than R4.3.1 (AK-SM 800A) or any end-of-life model.
Initial Access	T0822 External Remote Services	Access through refrigeration contractors' remote-monitoring and remote-management connections, as in the EFS supplier incident and the Leclerc supplier statement. [S6] [S8]	Inventory third-party remote access paths, and alert on contractor sessions outside agreed maintenance windows or from new source IPs.

Tactic	Technique	Procedure observed	Detection opportunity
Impair Process Control	T0836 Modify Parameter	Setpoints are raised (about +50 C) and defrost or temperature thresholds changed, driving refrigeration units into heating. [S3] [S7] [S8]	Use independent temperature sensors with alarms, and alert on any setpoint outside the defined safe range and on configuration-change events.
Impair Process Control	T0855 Unauthorized Command Message	Defrost or heating cycles are forced remotely and run continuously outside the schedule. [S3] [S5] [S6]	Compare defrost events against the approved schedule, and alert on manual or remote defrost commands outside maintenance windows.
Inhibit Response Function	T0838 Modify Alarm Settings	Settings are locked so operators cannot change them back, and the advisory warns of loss of visibility into actual temperatures. [S3] [S7]	Confirm that alarm thresholds match the baseline, and monitor for alarm-configuration changes and for a controller that reports normal values while independent sensors disagree.
Impact	T0815 Denial of View	The fact sheet lists loss of visibility into current temperatures as a possible effect. [S3]	Alert when telemetry from controllers or supervisors stops or flatlines, and cross-check against standalone data loggers.
Impact	T0828 Loss of Productivity and Revenue	Stock is discarded and stores are disrupted, with losses estimated in the tens of millions of euros for one French retailer group. [S6] [S7]	Not a detection point. Track it for business impact assessment.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

Inbound internet sessions to refrigeration controller web interfaces (firewall logs) `KQL`

```
let ControllerIPs = dynamic(["10.50.1.10","10.50.1.11"]); // replace with refrigeration controller / supervisor IPs
let ContractorIPs = dynamic(["203.0.113.10"]); // replace with approved contractor/VPN egress IPs
CommonSecurityLog
| where TimeGenerated > ago(30d)
| where DestinationIP in (ControllerIPs)
| where DestinationPort in (80, 443, 8080, 8443)
| where not(ipv4_is_private(SourceIP))
| where SourceIP !in (ContractorIPs)
| summarize Sessions=count(), FirstSeen=min(TimeGenerated), LastSeen=max(TimeGenerated), Ports=make_set(DestinationPort) by SourceIP,
DestinationIP, DeviceAction
| order by Sessions desc
```

Fill in the controller and contractor IP lists for each site. Any allowed session from a public IP that is not on the allowlist should be investigated. Denied sessions show scanning pressure.

Suricata - external HTTP/HTTPS to OT refrigeration VLAN `SURICATA`

```
alert tcp $EXTERNAL_NET any -> $REFRIG_CONTROLLERS [80,443,8080,8443] (msg:"OT - External connection to refrigeration controller management
interface"; flow:to_server; flags:S; threshold:type limit, track by_src, count 1, seconds 3600; classtype:policy-violation; sid:9100101;
rev:1;)
```

Define $REFRIG_CONTROLLERS in suricata.yaml. This is a policy rule that fires on any external connection attempt and does not detect exploit content.

Refrigeration setpoint or defrost changes outside safe range or maintenance window (BMS/supervisor syslog) `SPLUNK SPL`

```
index=ot sourcetype=refrigeration:syslog (setpoint OR "set point" OR defrost OR "alarm limit")
| rex field=_raw "(?i)(setpoint|set point)\D{0,10}(?<new_setpoint>-?\d+(\.\d+)?)"
| eval hour=strftime(_time,"%H")
| where (isnotnull(new_setpoint) AND new_setpoint > 8) OR match(_raw,"(?i)manual defrost|forced defrost|defrost start") OR hour<6 OR
hour>22
| stats count min(_time) as first max(_time) as last values(new_setpoint) as setpoints values(user) as users values(src) as sources by host
| convert ctime(first) ctime(last)
```

Field names and log formats vary by vendor (Danfoss, Copeland, Dixell), so adapt the extraction. Set the threshold per asset class, for example coolers versus freezers. Where the controllers produce no logs, use independent data-logger alarms instead.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Danfoss AK-SM 800 and AK-SC 355 (end of life)	All versions (no security updates; AK-SM 800 EOL May 2021, AK-SC 355 phased out 2016)	None; replace	None confirmed for this campaign	N/A	N/A	No	N/A
Danfoss AK-SM 8xxA series (AK-SM 800A)	Prior to R4.2 (CVE-2025-41450); prior to R4.3.1 (CVE-2025-41451, CVE-2025-41452). Outdated firmware units were hit in France; versions not named	R4.3.1 or later; latest package reported as 5.3.x (October 2026), upgrade via 4.x if on 3.x	CVE-2025-41450, CVE-2025-41451, CVE-2025-41452 (related; not confirmed as used)	v3.1 8.2 / 7.6 / 5.4 (v4 7.3 / 8.7 / 6.8)	0.0095 / 0.0446 / 0.0093 (2026-11-05)	No	N/A
Copeland xweb and Dixell xweb supervisors	Named by CERT-FR as compromised; versions not stated	Unknown; follow Dixell XWEB secure-use guidance (Oct 2026)	None named	N/A	N/A	No	N/A
Other electronic temperature and commercial refrigeration controllers / cold-chain monitoring platforms	Unpatched or internet-accessible units (no vendors named in the US fact sheet)	Per vendor	None named	N/A	N/A	No	N/A

Immediate (0–24 hours)

- Identify every refrigeration controller, supervisor and cold-chain monitoring system (including Danfoss AK-SM/AK-SC, Copeland/Dixell xweb), along

with contractor-managed remote links, and check from outside the network whether any are reachable from the internet. `IT OPS` [S3] [S5]
- Remove direct internet exposure for any unit with a public IP. Check service and insurance contract terms before cutting contractor data uplinks. As a stopgap only, restrict access at the firewall to contractor IPs. `IT OPS` [S3] [S5]
- Change all default passwords on controllers and supervisors, and enable the vendor's strict security mode (Danfoss Strict / HTTPS-only). `IT OPS` [S3] [S5] [S6]
- Review setpoints, alarm limits and defrost schedules on every unit against the documented baseline, and confirm that independent high-temperature alarms reach on-call staff. `SOC` [S3] [S5] [S8]
- If tampering is suspected, preserve logs and configuration first. Then isolate the unit, restart or factory-reset it, reconfigure it, and restore access only over VPN. Report the incident to CISA (contact@cisa.dhs.gov, 1-844-729-2472) or FBI IC3, and report healthcare supply-chain impact to HHS. `SOC` [S3] [S5] [S9]

Short term (1–7 days)

- Update AK-SM 800A units to current firmware (R4.3.1 or later; latest 5.3.x) and apply vendor firmware for xweb and other controllers. `IT OPS` [S3] [S6] [S10]
- Move OT controllers onto a dedicated OT VLAN separated from business networks, and route all remote maintenance through one managed VPN or jump host with MFA. `IT OPS` [S3] [S5]
- Enforce device and IP allowlisting for any host allowed to change controller configuration. `IT OPS` [S3]
- Turn on and centralize controller and supervisor logging. Where logs are not available, capture network traffic between OT assets. Review the last 90 days for unexpected logins or changes. `SOC` [S3] [S9]
- Contact refrigeration service contractors to confirm how they access client sites, which platform they use, and whether they were affected. `LEADERSHIP` [S6] [S8]

Long term

- Budget for and replace end-of-life controllers (AK-SM 800, AK-SC 355 and similar) that cannot be patched, because a factory reset does not prevent reinfection. `LEADERSHIP` [S5] [S6]
- Set up lifecycle management for OT and building-system devices, including an asset inventory, firmware tracking and EOL planning, in line with CISA CPG 2.A and 2.B. `IT OPS` [S3]
- Write security requirements into refrigeration and facilities service contracts: no direct internet exposure, VPN with MFA, named accounts, log retention and incident notification. `LEADERSHIP` [S3] [S9]
- Keep current offline backups of controller configurations and test the restore process. `IT OPS` [S3]

Workarounds & compensating controls

- Install independent temperature data loggers with cellular or separate-network alerting so that tampering cannot hide a temperature excursion. `IT OPS` [S3] [S8]
- Where the controller supports it, set hard minimum and maximum setpoint limits so units cannot be commanded outside safe ranges. `IT OPS` [S3]
- Prepare a manual fallback runbook covering local control override, transfer to backup refrigeration or reefer trucks, and stock-disposal decisions. `LEADERSHIP` [S7] [S8]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] BleepingComputer: FBI, CISA warn of cyberattacks targeting refrigeration systems
Published 2026-11-05 · `B1` Usually reliable, confirmed by other sources
Briefing source. Summarizes the joint fact sheet and the European and EFS incidents. No IOCs.

[S2] The Record (Recorded Future News): Cyberattacks on refrigeration systems prompt CISA, FBI warning
Published 2026-11-05 · `B2` Usually reliable, probably true
Briefing source. Adds the US commissary investigation and hybrid-threat context. No IOCs.

[S3] CISA / FBI / HHS / USDA / DOT: US Government Partners Urge Hardening Industrial Refrigeration and Cold Chain Monitoring Systems (joint fact sheet)
Published 2026-11-05 · `A2` Completely reliable, probably true
Primary source. TLP:CLEAR fact sheet and PDF. Names no vendors, CVEs or IOCs.

[S4] CISA: CISA, FBI, HHS, USDA, and DOT Urge Critical Infrastructure To Strengthen Industrial Refrigeration and Cold Chain Monitoring Systems Cybersecurity
Published 2026-11-05 · `A2` Completely reliable, probably true
Primary press release with agency quotes.

[S5] CERT-FR (ANSSI): CERTFR-2026-ALE-012 - Security incident targeting remote refrigeration controllers
Published 2026-10-12 · `A1` Completely reliable, confirmed by other sources
Primary national CERT alert, updated 13 and 16 October. Names Danfoss AK-SM/AK-SC and Copeland/Dixell xweb. No IOCs.

[S6] The Hacker News: Attackers Heat French Supermarket Fridges Up to 50C by Hijacking Danfoss Controllers
Published 2026-10-13 · `B2` Usually reliable, probably true
Detailed account of the October wave, with Danfoss EOL models, firmware guidance and retailer counts.

[S7] BleepingComputer: Hackers disrupt refrigeration systems at European supermarkets
Published 2026-11-02 · `B2` Usually reliable, probably true
Second wave: retailer-by-retailer counts across six countries, and the Sabcobel statement on reuse of the same vulnerability.

[S8] BleepingComputer: Cyberattack disrupts blood storage refrigeration systems in France
Published 2026-11-04 · `B2` Usually reliable, probably true
EFS three-site incident, with Coolworld Rentals confirming remote-monitoring software was involved.

[S9] EDRM: Supermarket freezer attacks reach at least six European countries, and the record linking them to US base failures stays thin
Published 2026-11-03 · `C2` Fairly reliable, probably true
Aggregates SecurityWeek, Reuters, Defense One, Lupovis and Censys reporting, and compares the CERT-FR and ACN guidance. Secondary source.

[S10] CISA: ICSA-25-140-03 Danfoss AK-SM 8xxA Series (Update A)
Published 2025-05-20 · `A2` Completely reliable, probably true
Primary ICS advisory for related CVEs. Updated 2025-08-26. Reported no known exploitation at the time.

[S11] Boston Globe: Freezers hacked in Europe; US military investigating
Published 2026-11-02 · `B2` Usually reliable, probably true
US commissary incidents at Fort Huachuca and Naval Station Newport. Pentagon IG and Army CID involvement.

[S12] FIRST: EPSS scores for CVE-2025-41450, CVE-2025-41451, CVE-2025-41452
Published 2026-11-05 · `A2` Completely reliable, probably true
EPSS model output: 0.00949, 0.04462 (91st percentile), 0.00925.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2025-05-20	CISA publishes ICSA-25-140-03 for the Danfoss AK-SM 8xxA authentication bypass (CVE-2025-41450), reported by Claroty Team82.	[S10]
2025-08-26	ICSA-25-140-03 Update A adds CVE-2025-41451 and CVE-2025-41452 (fixed in R4.3.1).	[S10]
2026-08-26	Freezers at US military commissaries, including Fort Huachuca and Naval Station Newport, unexpectedly go into defrost. The Pentagon later treats this as a suspected hack.	[S9] [S11]
2026-10-11	First wave: refrigeration at hundreds of French supermarkets is forced into defrost or heating overnight.	[S6] [S9]
2026-10-12	CERT-FR issues CERTFR-2026-ALE-012 naming Danfoss AK-SM/AK-SC. Copeland/Dixell xweb are added on 13 October and recommendations updated on 16 October.	[S5]
2026-10-20	Decoy sensors begin recording default-credential login attempts against Danfoss AK-SM interfaces, peaking on 26 October and running through 30 October.	[S9]
2026-11-02	Second wave overnight 1 to 2 November hits more than 115 stores in Belgium, the Netherlands, Sweden, Luxembourg, Ireland and Estonia, plus incidents in Italy and Portugal. Settings are changed at three EFS blood-storage sites the same day.	[S7] [S8] [S9]
2026-11-03	EFS publicly confirms the supplier-related incident, and Italy's ACN republishes its bulletin.	[S1] [S8] [S9]

Date	Event	Source
2026-11-05	CISA, FBI, HHS, USDA and DOT publish the joint fact sheet on hardening refrigeration and cold-chain systems.	[S3] [S4]

Relevance to Indianapolis, Indiana & managed clients

Indiana has a large cold-chain footprint. Food processing and agriculture, pharmaceutical and life-sciences manufacturing and distribution in central Indiana, Indianapolis-area logistics hubs and refrigerated warehouses along I-70 and I-65, hospital pharmacies and blood services, and independent grocers all depend on networked refrigeration controllers that are often installed and remotely managed by outside HVAC/R contractors. Those contractor connections often sit outside IT's view. Healthcare organizations, including hospitals, clinics, long-term care and blood or plasma centers, face patient-safety and regulatory consequences if vaccine, medication or blood-product storage is compromised. The EFS case shows that independent alarms are the control that prevented loss. School districts and universities with cafeteria walk-in freezers or research cold storage, and local governments with jail food service or public health vaccine storage, are also exposed. For managed IT service clients, the main risk is that refrigeration supervisors were connected to a public IP or a flat business network by a facilities vendor without IT's knowledge. Providers should run external exposure checks for client sites, add refrigeration and building-automation devices to asset inventories, put contractor remote access behind managed VPN with MFA, and make sure temperature-alarm notifications reach on-call staff after hours. No Indiana-specific incidents have been reported as of 6 November 2026.

Intelligence gaps

- The initial access vector for each wave has not been publicly confirmed. It is unknown whether default credentials, a known CVE, the unnamed vulnerability ANSSI reported to a Danish vendor, or a contractor platform compromise was used.
- No network IOCs (source IPs, tooling, user agents) have been released by CISA, CERT-FR, CCB or vendors. Watch for an updated CISA product or a CERT-FR or ACN revision.
- No attribution has been made. The Iran-linked suspicion for the US commissary events rests on anonymous sourcing, and the Russia hybrid-threat framing is speculative.
- It is not established whether the US commissary failures, the European supermarket waves and the EFS incident are linked. No US equipment vendor has been named.
- Firmware versions of the compromised AK-SM 800A units and of the Copeland/Dixell xweb units have not been disclosed.
- The product and third-party component behind the Coolworld Rentals / EFS incident are unknown.
- Whether US-sited refrigeration controllers have been tampered with beyond the military commissaries is unknown, and the fact sheet does not say whether US civilian victims exist.
- KEV status: CVE-2025-41450/41451/41452 did not appear in the part of KEV catalog version 2026.11.04 that was reviewed (full catalog not exhaustively checked). They are treated here as not listed.

Other notes

- A related earlier intel report, CTI-20261103-04 (2026-11-03), covers earlier phases of this activity. This report adds the 5 November joint US advisory.
- Victim counts for the October French wave differ by source: about 250 to 350 stores (press estimates), more than 350 establishments (Reuters) and about 700 of 10,000 supermarkets (French finance minister and prosecutors). The counting methods may differ.
- The fixed versions for the AK-SM 800A CVEs vary slightly between sources. CISA lists R4.2 for CVE-2025-41450 and R4.3.1 for the other two, so R4.3.1 or later covers all three. The CISA advisory's R4.3.1 download link was reported to point to a 4.2.4 package, so verify packages with Danfoss.
- CERT-FR's compromise-handling steps (restart or factory reset) do not mention preserving logs first. Italy's ACN advises preserving logs and configurations and reviewing 90 days of records. Preserve evidence before any reset.
- Belgian refrigeration installer Sabcobel said software updates alone are not enough and physical modifications are also required. Details were not provided.
- Reporting places the 2022 incidents against Russian supermarkets (AK-SM 800) and 40 Israeli stores as earlier precedents for this technique.

CTI-20261106-03 v1.0 · Generated 2026-11-06 08:05 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.